

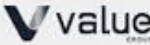
Sprint 3 – Conceitos Fundamentais da Auditoria de Sistemas

O que é Auditoria de Sistemas

A auditoria de sistemas é um processo de avaliação dos recursos tecnológicos, controles e procedimentos utilizados por uma organização. Seu objetivo é verificar se os sistemas operam de maneira segura, eficiente e de acordo com as normas e políticas estabelecidas.

Diferenças entre Auditoria Interna e Auditoria Externa

AUDITORIA INTERNA X AUDITORIA EXTERNA		
	INTERNA	EXTERNA
OBJETIVO	Avaliar e melhorar processos, controles e riscos	Emitir opinião sobre as demonstrações financeiras
VÍNCULO	Parte da estrutura da própria empresa	Independente, contratada de forma autônoma
FOCO	Eficiência operacional, governança, riscos e compliance	Conformidade contábil e legal
ABRANGÊNCIA	Personalizada, cobre todas as áreas da organização	Limitada às obrigações legais e financeiras
PERIODICIDADE	Contínua ou conforme plano interno	Trimestral, semestral, anual ou pontual

 Vvalue

Auditoria Interna

É realizada por profissionais vinculados à própria organização e possui foco na melhoria dos processos, na prevenção de riscos e no fortalecimento dos controles internos.

Auditoria Externa

É realizada por profissionais independentes e tem como objetivo emitir avaliações imparciais sobre a conformidade e a confiabilidade dos processos analisados.

Especificidades da Auditoria de TI

A auditoria de TI concentra-se na avaliação dos sistemas de informação, da infraestrutura tecnológica, dos controles de acesso, da segurança da informação e da proteção dos dados organizacionais.

Papel e Responsabilidades do Auditor



Entre as principais responsabilidades do auditor estão:

- Avaliar controles internos;
- Identificar riscos e vulnerabilidades;
- Verificar conformidade com normas e políticas;
- Elaborar relatórios de auditoria;
- Recomendar melhorias para os processos analisados.

Relação com o SDLC



A auditoria pode estar presente em todas as etapas do ciclo de vida do desenvolvimento de software (SDLC), verificando se os procedimentos adotados atendem aos requisitos de qualidade, segurança e conformidade.

Exemplos

Exemplo 1

Verificação dos acessos de usuários a um sistema corporativo para identificar permissões indevidas.

Exemplo 2

Avaliação dos procedimentos de backup para garantir a recuperação dos dados em caso de falhas.

Exemplo 3

Análise dos controles aplicados durante o desenvolvimento de um software para reduzir riscos de segurança.

Fontes de Pesquisa

<https://www.isaca.org/about-us>

<https://www.iso.org/standard/27001>

https://www.fca.pt?utm_